

WHEN AI ATTACKS

AI THREAT ASSESSMENT WORKBOOK

Digital Content #3 — Model Distillation: When Attackers Steal Your AI's Brain

Purpose: Assess your organization's exposure to model distillation attacks — where adversaries query your model APIs to replicate your proprietary AI's behavior. Map the governance gap, assign ownership, and build a prioritized response plan.

01 Exposure Check

Answer Yes / No / Unknown for your environment. Every Unknown is a gap. Three or more Unknowns = this is your next tabletop agenda.

Question	Yes	No	Unknown / Gap	Notes
Do you have a current inventory of all externally accessible model API endpoints?	☐	☐	☐	
Do shadow deployments and partner integrations appear in that inventory?	☐	☐	☐	
Do all APIs require authentication before serving model responses?	☐	☐	☐	
Do you know what each API returns: hard labels only, or also confidence scores / logits?	☐	☐	☐	
Have APIs returning probabilistic outputs had an information leakage risk assessment?	☐	☐	☐	
Are rate limits configured per authenticated client on all model APIs?	☐	☐	☐	
Do you have a process for offboarding API credentials when a partner relationship ends?	☐	☐	☐	

API INVENTORY (list externally accessible model endpoints)

API / Endpoint	Auth Required?	Response Type	Rate Limited?	Owner

02 Output Payload Audit

Logit-level outputs accelerate distillation attacks by 10–30x versus hard-label-only APIs. Audit each API's response payload against client requirements.

Question	Yes	No	Unknown / Gap	Notes
For each API, have you documented what response types are required for client use cases?	☐	☐	☐	
Have you assessed whether confidence scores / logits are functionally necessary?	☐	☐	☐	
Do APIs returning logit-level outputs have a documented business justification?	☐	☐	☐	
Have you evaluated whether hard-label-only responses would satisfy client requirements?	☐	☐	☐	
Have response payloads been reviewed by security for unintended information disclosure?	☐	☐	☐	

PAYLOAD REVIEW: For each API, document the response type and justify it

API / Endpoint	Response Type	Business Justification	Recommended Change

03 Detection Baseline

Volume-based rate limiting is insufficient. Distillation attacks distribute queries across accounts and slow extraction timelines to stay below thresholds.

Question	Yes	No	Unknown / Gap	Notes
Do you log all API queries at the gateway layer with client-level attribution?	☐	☐	☐	
Are per-client query volume baselines established and monitored?	☐	☐	☐	
Do you have alerting on anomalous query volume relative to per-client baselines?	☐	☐	☐	
Do you have semantic analysis on query content — not just volume monitoring?	☐	☐	☐	
Can you detect boundary-probing patterns (progressive variable manipulation, edge case clustering)?	☐	☐	☐	
Does your SIEM have defined signatures or ML models for adversarial query behavior?	☐	☐	☐	
Have you tested detection capability with simulated distillation queries?	☐	☐	☐	

04 Governance Gap — Who Owns What

The training data is classified. The knowledge extracted from it is not. Map ownership before an incident surfaces the gap.

Function	Owner (Name / Role)	Last Reviewed	Gap
Model API security monitoring			
Query anomaly detection and alerting			
Incident response — model extraction events			
Legal response — IP theft and attribution			
Data governance — obligations on extracted surrogates			

05 Five Questions for Your Next Executive Meeting

Question	Your Answer / Status
01 What is the estimated value of our proprietary model assets — training data, fine-tuning, calibration decisions — and is that	
02 Do we have baseline monitoring on query patterns for externally accessible model APIs, and what would anomalous behavior look	
03 If a competitor deployed a surrogate of our model tomorrow, what would be our legal recourse, and how long would attribution take?	
04 Who is the named owner of model security posture post-deployment — and does our data governance classify model	
05 Are our API response payloads returning more information than clients require, and have we risk-assessed the information content	

06 Directives — Assign an Owner and a Date

#	Audience	Directive	Owner	Done By
01	CISO	Inventory every externally accessible model API endpoint. Include shadow deployments and partner integrations. Assume your list is incomplete.		
02	CISO	Audit API response payloads. If you return logit-level outputs, assess whether hard-label responses would satisfy client requirements.		
03	CISO	Classify deployed model behavior as a protectable asset. Define what constitutes a breach of that asset class.		
04	CISO	Assign a named owner for model security posture post-deployment. If no role exists, that is your highest-priority governance finding.		
05	CISO	Update your breach definition to explicitly cover model knowledge extraction — not just data records accessed or exfiltrated.		
06	CISO	Engage legal on IP documentation, watermarking capability, and attribution evidence requirements.		
07	IR	Establish per-client query volume baselines for all model APIs. Anomaly detection against baselines is your earliest detection signal.		
08	IR	Define model extraction in your IR playbook: detection trigger, containment steps, legal notification threshold, and evidence set.		
09	IR	Run a cross-functional accountability tabletop: if our model were extracted today, who owns the response? Security, legal, and AI product must align.		

Assessment prepared by Matsui LLC · matsuihq.ai